Ex2 Thursday: keep-on-track sheet

Test runs 09:30 to 16:00. One 30-minute break: **email your supervisor when it starts and when it ends.** Screenshots: **max 5 pages A4.** Submission is final. **Actual start:** _____

Rules

1. 15 minutes over a box? Stop. Move on. Come back at the end.
2. Screenshot straight after each step. Log it on the evidence sheet.
3. Lab VMs only. Revert to **`clean`** after each test.
4. Never cut: pass evidence, the MERIT steps (A6, B5), the hashes, notes for tomorrow.
5. Stuck? Water, say “the next step is ____”, write your assumption, move on.
6. No messaging anyone and no AI chat during the test.

Highlighted (mandatory) topics in my brief: ☐ Malware ☐ Threats and attacks ☐ Assurance ☐ Legal and ethics ☐ Autopsy ☐ Justification

Schedule (09:30 to 16:00)

#	Block	Mins	Clock	Done
1	Start of day	30	09:30 to 10:00	☐
2	A. Malware (incl. MERIT A6)	120	10:00 to 12:00	☐
	Break + 2 emails to supervisor	30	12:00 to 12:30	☐
3	B1. Intel	25	12:30 to 12:55	☐
4	B2. Threat model	25	12:55 to 13:20	☐
5	B3. Scans	40	13:20 to 14:00	☐
6	B4. Attacks	40	14:00 to 14:40	☐
7	B5. MERIT: processes	15	14:40 to 14:55	☐
8	Tidy, log, upload	50	14:55 to 15:45	☐
9	Buffer	15	15:45 to 16:00	☐

Email sent at break start: ☐ _____ Email sent at break end: ☐ _____

Quick ticks

1 Start (30) ☐ folders ☐ brief read, verbs highlighted ☐ rules of engagement written ☐ VM snapshots **`clean`** ☐ app running, **`test_sync.sh`** 10 PASS ☐ Nessus activating ☐ sample downloaded in VM ☐ M57-Jean hashed

2 Malware (120) ☐ A1 safe setup + SHA-256 ☐ A2 triage + strings ☐ decision point: obfuscated enough for Merit? ☐ A3 Any.run run + screenshots ☐ A4 static vs dynamic ☐ A5 verdict + YARA + CareLink actions ☐ **A6 MERIT: obfuscation / anti-RE** ☐ VM reverted

3 to 5 Threats (90) ☐ B1 method, sources, intel demo, enriched view, 3 threats ☐ B2 diagram + STRIDE with Intel column ☐ B3 nmap ☐ Nikto ☐ dirb ☐ Burp ☐ Nessus export

6 to 7 Attacks and processes (55) ☐ SQLMap ☐ 200 wrong tokens ☐ abuse table ☐ one fix retested ☐ DB cleaned ☐ **B5 MERIT: process threats**

8 Wrap (50) ☐ evidence log complete ☐ screenshots within 5 A4 pages ☐ hashes noted ☐ sample removed from upload ☐ upload done and confirmed (final) ☐ Autopsy opens ☐ Friday sticky note

Distinction (if ahead) ☐ own script/tool edit ☐ process mitigations

Sheet A: malware capture

Sample

Item	Value
SHA-256	
MD5 / SHA-1	
Source and date	
VirusTotal family / detections	
File type and size	
Packed? Entropy	
Obfuscation / anti-analysis seen	
Tool used for dynamic run	

Sections and entropy

Section	Size	Entropy	Note

ATT&CK techniques

ID	Technique	Tactic	Confirmed or suspected	Fig

IOCs

Type (IP, domain, URL, file, key, mutex)	Value	Seen in (static / dynamic)

Static vs dynamic

Behaviour	Static	Dynamic	Agree?
Starts processes / injects			
Persistence			
Network / C2			
Files / data touched			
Evasion			

Verdict (one line): _____

Five headings (how it gets in / runs / persists / talks out / hides):

Heading	What I found	Fig
Gets in		
Runs		
Persists		
Talks out		
Hides		

MERIT: obfuscation and anti-reverse-engineering

Technique	Seen? What I saw	How I got past it
Packing / encryption		
Dynamic API resolution		
Anti-debugging		
Anti-VM / sandbox		

YARA: hit on sample ☐ no hit on clean file ☐ What I changed: _____

CareLink actions

Action	Detect, contain or mitigate	Links to my Ex1 control

Sheet B: threats and attacks results

Three threats (B1)

#	Threat	Asset	Source (rated A/B/C)	Ex1 control
1				
2				
3				

Enriched view (B1): two or more sources combined

Threat	Source 1 says	Source 2 says	Meaning for CareLink
1			
2			
3			

Top 3 risks from STRIDE (B2)

Threat	Likelihood 1-5	Impact 1-5	Score	After controls

Scans (B3). Target IP: _____

Tool	Top finding	Real or false positive?	Action	Fig
nmap				
Nikto				
dirb				
Burp				
Nessus				

Attacks (B4)

Attack	Worked?	Impact if it had	Why it held / fix	Fig
SQLMap				
200 wrong tokens				
Read-only token writes				
Revoked token				
Expired token				
Same note twice				
3 MB note				
Malformed JSON				
GET not POST				
Token over plain HTTP				

Fix I applied and retested: _____ Before: ____ After: ____

IDOR / bad upload: not applicable because _____

MERIT (item 12): threats to processes. DISTINCTION: mitigations

Process threat	Mitigation (Distinction)
Helpdesk reset	
Supplier access	
Leavers	
Staff enabling a phish	

Sheet C: evidence log

Hashes (record before opening anything)

Item	SHA-256	Source	Date
Malware sample			
M57-Jean image			

Fig	What it shows	File name	Used in
01			
02			
03			
04			
05			
06			
07			
08			
09			
10			
11			
12			
13			
14			
15			
16			
17			
18			
19			
20			